

Information Security Policy

Policy ID ISP-2026-01 · Effective 1 January 2026 · Classification: Confidential

1. Purpose and scope

This policy establishes mandatory controls for protecting Northstar Holdings information assets, including customer records, financial data, source code, and audit workpapers. It applies to all employees, contractors, and vendors with network or document access. The Data Protection Officer is Morgan Ellis (dpo@northstar.example). Exceptions require written approval from the Chief Information Security Officer.

2. Password and authentication standard

All interactive accounts must use a minimum password length of 14 characters, mixing upper and lower case letters, a numeral, and a symbol. Passwords must be rotated every 90 days and must not reuse any of the prior 12 passwords. Shared service accounts are prohibited except where a vaulted credential is approved by Security Engineering. Multi-factor authentication is required for privileged access, remote VPN, and any system that stores Confidential or Restricted data. Passwords must never be stored in plain text, tickets, or chat messages.

3. Data classification

Information is labeled Public, Internal, Confidential, or Restricted. Public information may be published externally. Internal information is for workforce use and includes the employee handbook and office procedures. Confidential information includes audit procedures, risk reports, and customer contracts. Restricted information includes incident response runbooks, encryption keys, and unpublished vulnerability findings. Restricted and Confidential data must not be sent through personal email, unsanctioned cloud drives, or removable media without encryption and CISO approval.

4. Access control

Access follows least privilege and role-based permissions. New access requests are ticketed, approved by the data owner, and provisioned within two business days. Access reviews occur quarterly for Confidential systems and monthly for Restricted systems. Terminated workforce members must have all access revoked within four hours of HR notification. Privileged sessions on production systems are recorded and retained for one year.

5. Acceptable use

Company laptops must run the approved endpoint agent, full-disk encryption, and automatic screen lock after 10 minutes of inactivity. Software may be installed only from the internal catalog. Personal cloud backup of company documents is forbidden. Security event logging on servers is retained for 365 days. Suspected phishing must be reported to soc@northstar.example within one hour of discovery.

6. Enforcement

Violations are investigated by Corporate Security and may result in disciplinary action up to termination and referral to law enforcement. This policy is reviewed annually or after a material incident. The current control owner is the CISO, reporting to the Audit and Risk Committee of the Board.